



— WHITE PAPER

Implementing NIS2 and ISO 27001 **pragmatically**

A guided path for mid-sized companies and public bodies, from "Are we in scope?" to evidence an auditor will accept.

— AFTER READING, YOU WILL KNOW

- ✓ what Germany's NIS2 Implementation Act has required of you since 6 December 2025,
- ✓ how far an existing ISO 27001 management system takes you, and where it stops,
- ✓ how to get to a status that holds up, in five steps.

The UniqSuite team

Practice as CISO and lead auditor (ISO/IEC 27001, 42001)
20+ years in information security and compliance

uniq.cyberwerk.online

Not legal advice: see the note on page 14

At a glance

In Germany, NIS2 is no longer a future topic. The implementation act has applied since December 2025, with no general transition period, and the EU AI Act and Cyber Resilience Act deadlines are now starting to bite. Act methodically now and the effort stays manageable: you reach a status that management, supervisors and auditors can follow.

1

The obligations already apply

The NIS2UmsuCG entered into force on 6 Dec 2025. An estimated 29,500 entities now fall under the new BSI Act (BSIG), against roughly 4,500 critical-infrastructure operators before. The registration deadline has passed.

2

Management is personally accountable

Management must implement the risk-management measures, oversee their implementation and attend training regularly. It can delegate the work, not the responsibility.

3

Ten measures, three reporting deadlines

The law requires ten minimum measures (Section 30 BSIG, Art. 21 NIS2) and incident reports at 24 hours, 72 hours and one month. Fines run up to €10m or 2% of worldwide turnover.

4

ISO 27001 is the backbone, not the finish line

A working ISMS covers much of the ground. Incident reporting, registration, management training and the depth of supply-chain checks still need targeted work.

5

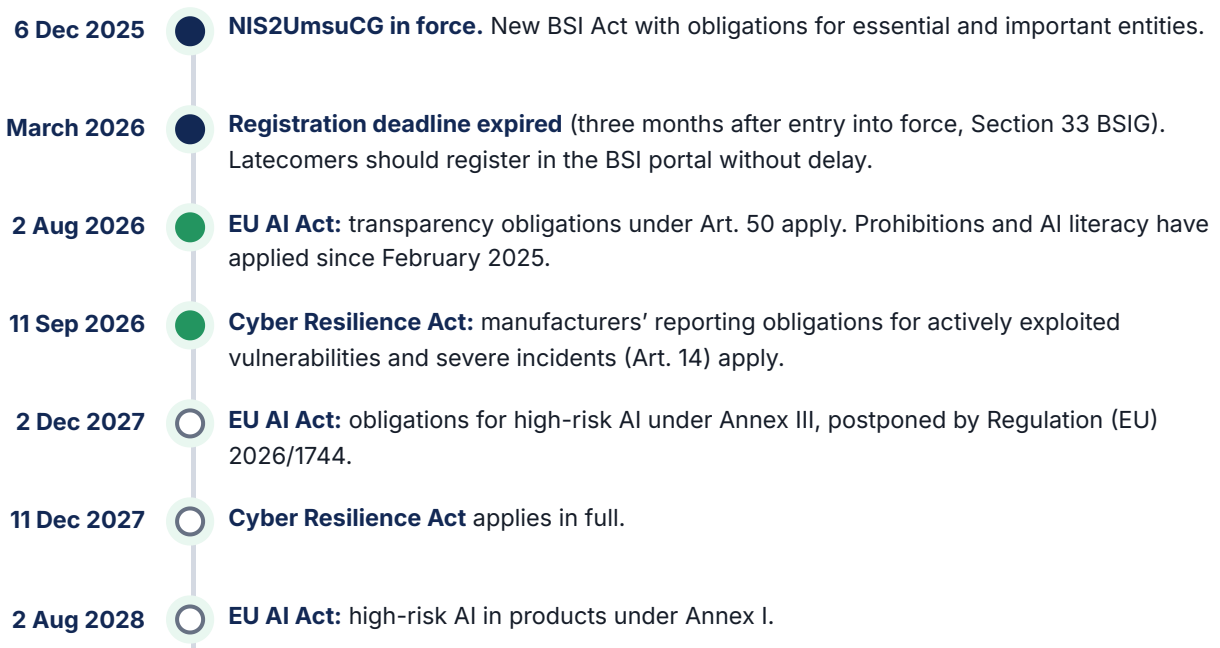
The usual bottleneck is overview

Most organisations know some of their gaps. What they lack is one current view: which requirement applies, where it stands, who does what by when, and what can be evidenced. This white paper sets out a tool-independent path to that view; pages 11 to 13 show how UniqSuite supports it.

Where things stand

On 5 December 2025 Germany promulgated its “Act implementing the NIS 2 Directive and regulating essential principles of information security management in the federal administration” (NIS2UmsuCG, Federal Law Gazette 2025 I No. 301). The act recast the BSI Act and entered into force the next day, with no general transition period for the security measures.

The question has moved from “Is it coming?” to “How far along are we?”, and other European rules now run in parallel for many organisations:



Why it is urgent. Bitkom puts the damage from data theft, espionage and sabotage in Germany at €211bn or more for 2026. Cyberattacks cause around three quarters of it, and 96% of the companies surveyed were affected or suspect they were.

Bitkom, Wirtschaftsschutz 2026, n = 1,003

Beware of outdated material. Many guides still give 17 October 2024 as Germany's start date, 2 August 2026 for high-risk AI, or a single tier of fines. All three are out of date, so check when each source was written.

Are we in scope?

Two questions usually decide whether an entity falls under the BSI Act: does it operate in a covered sector, and does it reach the size threshold? Some services are covered regardless of size. The overview below is deliberately simplified.

1 · Do you provide services in a covered sector?

Sectors of high criticality

Energy, transport, banking and financial market infrastructure, health, drinking water, waste water, digital infrastructure, ICT service management, space, federal public administration

Other critical sectors

Postal and courier services, waste management, chemicals, food, manufacturing (incl. medical devices, electronics, machinery, vehicles), digital providers, research



2 · How large is your entity? (group figures may count)

Large enterprise

250+ employees, or more than €50m turnover and more than €43m balance sheet total

high criticality → essential

other → important

Medium-sized enterprise

50+ employees, or more than €10m turnover and more than €10m balance sheet total

both sector groups → important

Smaller

Usually not covered, **except** for services caught regardless of size, e.g. qualified trust services, TLD registries, DNS services or public electronic communications.

Public bodies. The BSI Act covers the federal administration; state and municipal administrations fall under the rules of the individual German states. Municipal companies such as public utilities, hospitals or waste-management firms may come directly under the BSI Act.

Indirectly affected. Organisations outside the scope still feel NIS2 through their customers, who must check the security of their supply chain and pass requirements on by contract.

Only a case-by-case assessment settles whether you are in scope; the BSI's applicability check (bsi.bund.de) helps. Record the result with a date and reasons, even when the answer is "not in scope".

Ten minimum measures and where the gaps usually are

Section 30 BSIG adopts the ten measures of Art. 21(2) of the NIS2 Directive. They must be appropriate, proportionate and effective, and follow an all-hazards approach. For each measure the table gives the matching ISO/IEC 27001:2022 reference, the gap that most often remains in practice and the evidence auditors ask for.

Measure	ISO 27001:2022	Typical gap	Evidence
a · Risk analysis and security policies	Cl. 6.1.2, 6.1.3, 8.2; A.5.1	Risk analysis without the supply chain and without an all-hazards view	Approved policy, current risk report
b · Incident handling	A.5.24–A.5.28, A.6.8	No defined criterion for “significant”, no rehearsed reporting route to the BSI	Incident register, reporting templates, exercise record
c · Business continuity, backup, crisis management	A.5.29, A.5.30, A.8.13, A.8.14	Restore never tested, crisis team only on paper	Contingency plans, restore test records
d · Supply-chain security	A.5.19–A.5.23	Suppliers listed but not rated by criticality	Supplier assessments, contract clauses
e · Security in acquisition, development and maintenance, incl. vulnerabilities	A.5.20, A.8.8, A.8.25–A.8.29	Patching without deadlines, no vulnerability disclosure process	Vulnerability and patch reports

More detail for digital services. Implementing Regulation (EU) 2024/2690 spells out the technical and methodological requirements for certain providers: DNS services, TLD registries, cloud and data-centre services, content delivery networks, managed (security) services, online marketplaces, search engines, social networks and trust services. If you are one of them, align your gap analysis with that regulation.

Continued overleaf. The mapping to ISO 27001 is our professional assessment, not an official concordance.



IN THE AUDIT

Auditors check what you can show. A measure without evidence does not count in the conversation.

Measure	ISO 27001:2022	Typical gap	Evidence
f · Assessing effectiveness	Cl. 9.1, 9.2; A.5.35	Audits yes, effectiveness metrics no	Metrics, audit reports, management review
g · Cyber hygiene and training	Cl. 7.2, 7.3; A.6.3	Staff trained, management not	Training records incl. management
h · Cryptography and encryption	A.8.24	Encryption in use, but no concept and no key management	Cryptography concept
i · HR security, access control, asset management	A.5.9–A.5.18, A.6.1–A.6.5	Inventory incomplete, access rights never recertified	Inventory, recertification records
j · MFA, secured communications, emergency communications	A.5.14, A.8.5	MFA only for remote access, no emergency communication channel	MFA coverage, emergency communication plan

Reporting significant incidents (Section 32 BSIG, Art. 23 NIS2)

24 h Early warning from awareness	72 h Incident notification with initial assessment	on request Intermediate report	1 month Final report after the notification
---	--	--	---

If the incident is still ongoing, a progress report initially replaces the final report. Agree in advance when an incident counts as "significant", or the debate starts while the clock is already running.

Fines (Section 65 BSIG, Art. 34 NIS2)

Entity	Maximum (whichever is higher)
essential	€10m or 2% of worldwide annual turnover
important	€7m or 1.4% of worldwide annual turnover

Registration (Section 33 BSIG)

Covered entities must register with the BSI and report any change to their details. The statutory three-month deadline after entry into force has expired. If you have not registered, do so without delay and record who keeps the details up to date.

Management in the driving seat

Section 38 BSIG transposes Art. 20 of the Directive and speaks to management directly: it must implement the risk-management measures, oversee their implementation and attend training regularly. Management that culpably breaches these duties is liable to the organisation under company law.

Implement

Policy, risk treatment and action plan are formally approved and put into effect, with a dated record.

Oversee

Progress comes up for review regularly: what is done, what is overdue, where do the risks lie?

Train

Management learns enough to recognise risks and judge the measures.

Seven questions management should be able to answer

1. Are we an essential or an important entity, and is the reasoning in writing?
2. Are we registered with the BSI, and who keeps the details current?
3. Which requirements are open, and which are mandatory?
4. Who reports a significant incident within 24 hours, including at the weekend?
5. Which suppliers are critical to us, and when were they last assessed?
6. When did we last successfully test a restore from backup?
7. When did management itself last attend training?

Practical tip: one page is enough. A monthly one-page report with overall status, overdue measures and open mandatory requirements serves the oversight duty better than an annual slide deck, and it can be filed as evidence.

— MANAGEMENT DUTY

Management implements the measures, oversees their implementation and attends training regularly. The work can be shared, the accountability cannot.



ISO 27001 as the backbone, and what it leaves out

An organisation running an ISMS under ISO/IEC 27001 already has the foundation that matters most: scope, risk method, roles, document control, internal audits and management review. NIS2 builds on exactly these mechanisms. Blanket figures for how much a certificate “covers” still mislead. What counts is whether the measures are effectively implemented within the scope.

What a working ISMS brings

- ✓ A method for risk assessment and treatment
- ✓ A Statement of Applicability (SoA)
- ✓ Roles, responsibilities, document control
- ✓ Internal audits, corrective actions, management review
- ✓ Most of the technical and organisational controls of Annex A

What needs targeted work

- **Scope:** it must cover all in-scope services, not just a certified slice.
- **Incident reporting:** significance criteria, 24/72-hour process, reporting authority.
- **Registration** with the BSI and keeping the details current.
- **Management:** implementation, oversight and training as evidenced duties.
- **Supply chain:** assessment of direct suppliers' security practices, including development procedures.
- **Emergency communications** and secured communications.

Assess once, use many times

Many requirements in NIS2, ISO 27001, ISO 42001, the AI Act and the CRA ask for the same thing: access control, incident handling or supplier assessment, for example. Kept apart, they get answered several times, and the answers can contradict each other. A shared control point, assessed once and counted in every affected framework, avoids this. Where one answer serves several frameworks, the weakest implementation prevails in case of doubt.



— MAINTAIN ONCE

A requirement assessed properly once supports several frameworks at the same time. No duplicate work.

The guided path in five steps

The path follows the Plan-Do-Check-Act cycle that ISO 27001 and supervisors expect. It works with or without a tool, as long as each step produces a result the next one uses.



Example: Nordwerk Energie GmbH

Fictitious company, demo data from UniqSuite

This regional energy supplier has around 400 employees, is in scope as an essential entity and is working towards ISO 27001 certification. Some of its processes use AI, so it also covers the AI Act and ISO 42001.

After the gap analysis the overall status is 59%. One page shows management what needs attention: two overdue measures, one reporting deadline and the open mandatory requirements per framework. These become an action plan with owners and deadlines, whose progress feeds automatically into the overall status.

Framework	Requirements	Status
NIS2	268 · 241 applicable	60%
ISO/IEC 27001	318 · 315 applicable	62%
ISO/IEC 42001	111 · 107 applicable	60%
EU AI Act	130 · 108 applicable	46%

Weighted implementation status per framework in the demo tenant

Maturity, not just yes or no. For a first pass, implemented, partial or not implemented is enough. In the detailed pass, a maturity scale with evidence per requirement pays off: it shows progress before a gap is fully closed.

Six typical mistakes



Settling applicability only verbally

Without a dated, reasoned assessment, the first piece of evidence is missing.



Sorting out reporting on the day

If you define "significant" after the incident, you lose the 24 hours.



"Not applicable" without justification

Every exclusion needs traceable reasoning in the SoA.



Adopting the ISMS scope unchecked

The certified area often does not cover all in-scope services.



One spreadsheet per framework

Duplicate work and contradictory answers to the same question.



Merely informing management

Implementation, oversight and training must be evidenced.

Frequently asked questions

Is there an "NIS2 certificate"?

No. The law provides for no general certification. An ISO 27001 certificate strongly indicates a working ISMS but does not replace evidence that the statutory obligations are met.

We are ISO 27001 certified. Are we done?

Not automatically. Check scope, incident reporting, registration, management duties and the supply chain (page 8).

How long does a gap analysis take?

It depends on size and prior work. Well prepared, you can complete a first full pass in a few working days; the detailed pass with evidence takes longer.

We are a municipality. Does the BSI Act apply to us?

Your municipal administration falls under the rules of your German state. Municipal companies, however, may come directly under the BSI Act.

Do we have to meet all requirements immediately?

The obligations have applied since December 2025. If you still have gaps, you need a prioritised plan approved by management, and visible progress against it.

What if we also use AI?

The AI Act applies independently of NIS2. AI literacy and the prohibitions already apply; start with an AI register. ISO 42001 supplies the management system.

— WORKING TOGETHER

Business units and information security see the same status. Gaps show up before an auditor finds them.



How UniqSuite supports the path

UniqSuite is a deliberately simple tool built for this path. It takes you through six phases from scope to audit, has you assess each requirement once and produces the reports management and auditors expect.



Welcome to UniqSuite
Three questions, then you're ready.

1 Company

2 Package

3 Size

What do you need to demonstrate?

NIS2
Legal duty for important and essential entities.

ISO 27001
Certifiable information security management system.

NIS2 + ISO 27001
Both together — identical requirements are assessed once.

In addition (optional)
☒ EU AI Act
☐ ISO 42001 (AI management system)
☐ Cyber Resilience Act (products with digital elements)

< Back

Next >

Set-up in three questions: company and sector, package, size

Ready in three questions

Company and sector; the package you need (NIS2, ISO 27001 or both, optionally with the AI Act, ISO 42001 and the CRA); and the number of employees. The gap analysis opens straight away.

Five catalogues, 910 assessable requirements

NIS2	268
ISO/IEC 27001	318
EU AI Act	130
ISO/IEC 42001	111
Cyber Resilience Act	83

227 shared control points link 454 equivalent requirements across frameworks. One answer counts automatically wherever the same control point is used.

One question per card, or the full table

Assess requirement 89 open

Open only All

AIACT-A-01.1 MUST A-01

1 of 89

Is it ensured that no AI system is used to evaluate or classify natural persons over time on the basis of social behaviour or known, inferred or predicted personal or personality characteristics where the resulting score leads to detrimental or unfavourable treatment in unrelated social contexts or treatment that is unjustified or disproportionate (Article 5(1)(c))?
[Optional internal policy: no social scoring of any kind.]

✓ Implemented

⦿ Partial

× Not implemented

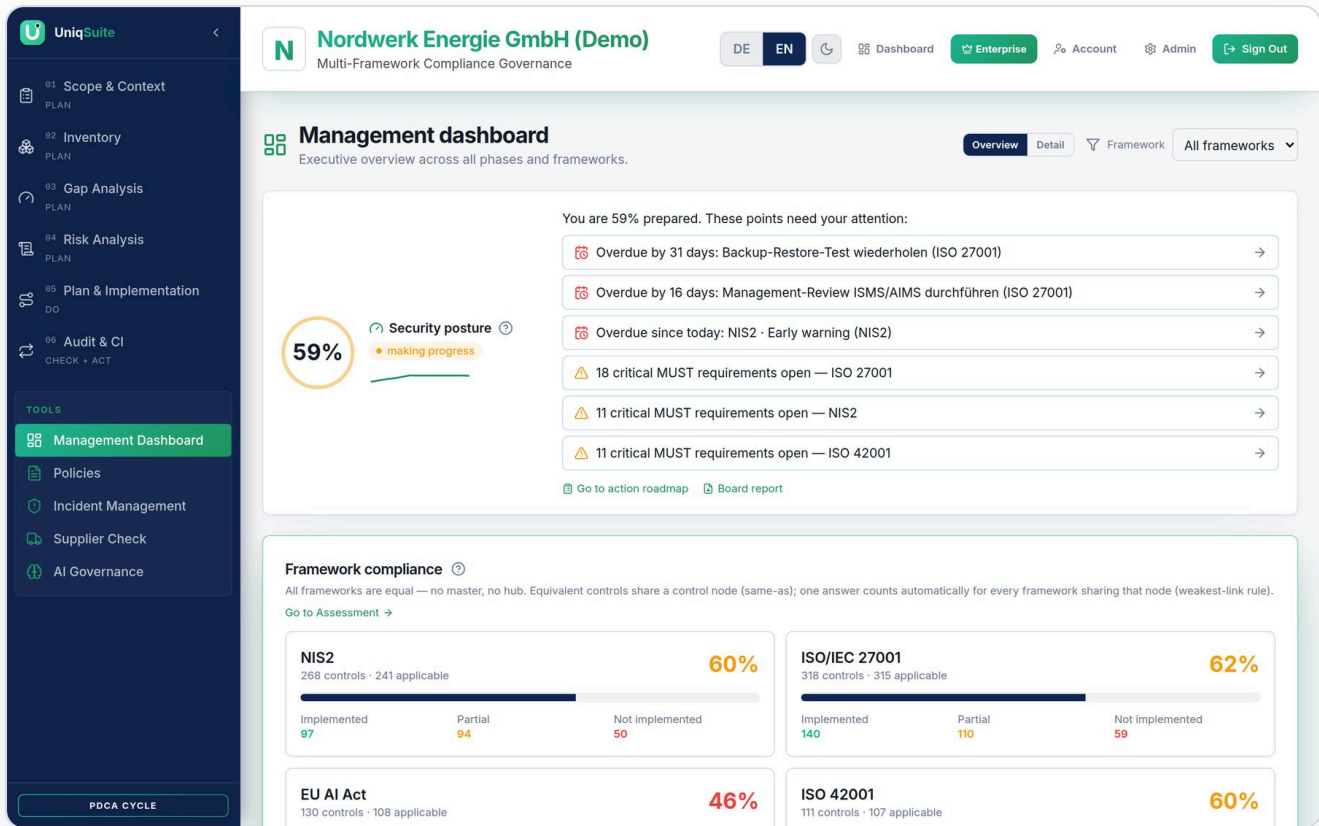
Not applicable ...

< Back

Next >

Overview: mandatory requirements first, answered with one click. "Not applicable" needs a justification for the SoA. Detail mode adds maturity, evidence and notes per requirement.

One status for management, team and auditors



Management dashboard: overall status, trend and the points that need attention now. Demo tenant.

From requirement to evidence

Requirement	Support in UniqSuite	Result / evidence
Applicability and scope	Phase 01 "Scope & Context": company, sector, size, people, frameworks	Scope report
Risk analysis (a)	Phase 04: derive risks from gaps, assess, treat	Risk report (PDF, Word, Excel)
Incidents and reporting (b)	Incident management: reporting duties per framework, deadline timers, directory of reporting authorities, MTTD/MTTR	Incident register, register report
Supply chain (d)	Supplier check: criticality, controls, risk score, review cycle	Supplier assessment
Policies (a, g, h, i)	Policy templates linked to the requirements	Policies ready for approval
Implementation and management	Phase 05: SoA and one list of measures with owners, deadlines, status	SoA, implementation and board report
Effectiveness (f)	Phase 06 "Audit & CI": findings, corrective actions, follow-up	Audit report

TRUST

Secure and traceable

- ✓ **Tenant separation in the database:** row-level access rules keep every organisation's data apart.
- ✓ **Two-factor sign-in**, which can be made mandatory for administrators.
- ✓ **Daily backups** with 14-day retention.
- ✓ **Rule-based, not a black box:** assessments and metrics follow fixed, traceable rules, and no AI decides your status.
- ✓ **Up to date:** the catalogues already reflect the AI Act deadlines as amended by Regulation (EU) 2026/1744.

TO BE CLEAR

What UniqSuite does not replace

A tool gives you overview and evidence. It does not replace

- the legal assessment of whether you are in scope,
- management's decisions and accountability,
- the technical security measures themselves,
- an independent audit or certification.

OUTLOOK

AI and products: the next obligations

EU AI Act

Prohibitions and AI literacy have applied since February 2025, transparency obligations since August 2026. High-risk AI follows from December 2027. First step: an AI register.

ISO/IEC 42001

The management system for AI. It shares the structure of ISO 27001, so an existing ISMS is a base to build on.

Cyber Resilience Act

Since September 2026, manufacturers of products with digital elements must report actively exploited vulnerabilities. The CRA applies in full from December 2027.

Your 30-day plan

Week 1

Document applicability, check registration, name owners.

Week 2

First pass of the gap analysis, mandatory requirements first.

Week 3

Define the reporting process and assess critical suppliers.

Week 4

Have management approve the action plan, file the first report.



SUPPORT

UniqSuite organises the work. Assessment and decisions stay with your experts.

See your status in a single view.

Three set-up questions, then the first requirement. Request access or book a short demo with your own questions.

uniq.cyberwerk.online

Sources

1. Directive (EU) 2022/2555 (NIS2), in particular Art. 20, 21, 23, 34 – eur-lex.europa.eu/eli/dir/2022/2555/oj
2. German NIS2 Implementation Act (NIS2UmsuCG), Federal Law Gazette 2025 I No. 301 of 5 Dec 2025 – recht.bund.de/bgbl/1/2025/301/VO.html
3. BSI: NIS-2-regulated companies, registration and applicability check – bsi.bund.de
4. Regulation (EU) 2024/1689 (AI Act) – eur-lex.europa.eu/eli/reg/2024/1689/oj
5. Regulation (EU) 2026/1744 amending the AI Act – eur-lex.europa.eu/eli/reg/2026/1744/oj
6. Regulation (EU) 2024/2847 (Cyber Resilience Act) and reporting obligations – digital-strategy.ec.europa.eu/en/policies/cra-reporting
7. ENISA: Single Reporting Platform for the CRA, September 2026 – enisa.europa.eu
8. Bitkom: Wirtschaftsschutz 2026, presentation, August 2026 – bitkom.org
9. Number of covered entities in Germany: reporting on the cabinet decision, incl. cio.de and channelpartner.de
10. Implementing Regulation (EU) 2024/2690 – eur-lex.europa.eu/eli/reg_impl/2024/2690/oj
11. ISO/IEC 27001:2022 and ISO/IEC 42001:2023 – iso.org

Note. This white paper is for general information. It is not legal advice and does not replace a case-by-case assessment. The mapping to ISO/IEC 27001 is our professional assessment. All company names and figures in the example are fictitious and come from a demo tenant. ISO and IEC are trademarks of their respective owners.

